UNIVERSITI TEKNOLOGI MARA
MARKING SCHEME

COURSE	:	COMPUTER SECURITY
COURSE CODE	:	CSC662
EXAMINATION	:	OCTOBER 2026 (MOCK)
TIME	:	3 HOURS

MARKING SCHEME NOTES

1. This marking scheme accompanies the CSC662 mock paper (October 2026). Computed answers show working; theory answers are supported by lecture slides (not lecturer-marked) with a verbatim quote and slide citation.

2. Supported theory marking points quote the lecture decks; any unresolved slot would remain a visible placeholder.

3. Part A = 10 x (2 + 6); Part B = 2 x (5 + 5); total = 100 marks.

4. Computed: 0 slot(s). Supported theory: 24 slots. Placeholders: 0. Questions and answers are for local study use only.

5. Near-copy rejection used all 35 past papers; style widening is recorded per slot.

FOR MARKERS' USE ONLY

This marking scheme consists of 15 printed pages

© Hak Cipta Universiti Teknologi MARA

CSC662 - MARKING SCHEME (MOCK OCTOBER 2026)

Labels: computed / supported by lecture slides (not lecturer-marked) / placeholder. No official marking scheme exists for the real CSC662 papers; this is generated for the mock.

Entailment labels: supported = the quote directly supports the marking point (or the point passed the stem-overlap gate without an LLM check); partly supported = the quote supports part of the point or is ambiguous; not supported = the quote does not support the point. Only 'not supported' points triggered regeneration.

Part A: 10 x (2 + 6) = 80 marks. Part B: 2 x (5 + 5) = 20 marks. Total: 100 marks. Slots: 0 computed, 24 supported by lecture slides, 0 placeholder.

Methods: computed answers use verified solvers. Theory answers are supported by lecture slides (not lecturer-marked). Each marking point carries a verbatim quote, a deck/slide/chunk citation and a term-overlap score; low overlap is flagged for human review. Sources are restricted to the slot topic's allowed decks, and a slide is not reused across questions where an alternative exists.

PART A - QUESTION 1

A1a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

State TWO (2) reasons why software is insecure, with particular reference to buffer overflows.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Software insecurity arises because an attacker can alter system resources that are critical for program execution, such as the instruction pointer or function call addresses.	"Software insecurity stems from attacker's ability to modify system resources criticial for program execution, e.g. instruction pointer, function call addresses, interrupt addresses, etc."	051 - Software Security, slide 30	051 - Software Security::s30::1	0.67	supported (ste gate)
2	A key source of software insecurity is the failure to validate user input.	"One of the key sources for software insecurity is failed validation of user input."	051 - Software Security, slide 30	051 - Software Security::s30::1	0.86	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 051 - Software Security, slide 30

A1b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Windows provides a rich set of security mechanisms, yet its complexity is often described as its own worst enemy. Explain six aspects of Windows security mechanisms, covering their purpose, the components involved, and the risks that arise from their complexity.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Windows offers elaborate mechanisms for managing user accounts, objects and access control.	"Windows systems contain complex security mechanisms for user account and object management as well as access control."	041 - Windows Security, slide 21	041 - Windows Security::s21::1	0.80	supported (ste gate)
2	Discretionary access control in Windows allows fine-grained control over diverse entities, both in the OS and in applications.	"DACS enable fine-grained access control of heterogeneous entities in Windows itself as well as applications."	041 - Windows Security, slide 21	041 - Windows Security::s21::1	0.50	supported (ste gate)
3	The very complexity of these mechanisms means that	"The complexity of Windows security mechanisms is also its enemy: misconfiguration as well	041 - Windows Security, slide 21	041 - Windows Security::s21::1	0.50	supported (ste gate)

© Hak Cipta Universiti Teknologi MARA

	misconfiguration or implementation bugs can cause serious security incidents.	as implementation bugs may lead to severe security incidents."				
4	Active Directory, introduced with Windows 2000, is an LDAP-like directory service used to organise system resources.	"Active directory introduced in Windows 2000 is an LDAP-like directory service for organization of system resources:"	041 - Windows Security, slide 6	041 - Windows Security::s06::1	0.91	supported (ste gate)
5	Active Directory manages users and groups, security credentials and certificates, and system resources such as desktops, servers and printers.	"Users and groups Security credentials and certificates System resources (desktops, servers, printers)"	041 - Windows Security, slide 6	041 - Windows Security::s06::1	0.64	supported (ste gate)
6	In Windows, subjects are processes and threads, and their security credentials are held in a token that is inherited when new processes are created.	"Windows subjects are processes and threads. Security credentials for a subject are stored in a token."	041 - Windows Security, slide 11	041 - Windows Security::s11::1	0.58	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 041 - Windows Security, slide 11; 041 - Windows Security, slide 21; 041 - Windows Security, slide 6

PART A - QUESTION 2

A2a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain two characteristics of Trojan horse malware as described in the lecture, focusing on how it behaves and what harm it causes.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Trojans disguise themselves as useful or benign programs so users accept them.	"They usually masquerade as helpful or harmless programs"	051 - Software Security, slide 12	051 - Software Security::s12::1	0.12 LOW	supported
2	Once running, a Trojan steals private data, deletes files, logs keystrokes or opens a way for further malware.	"begin to steal private data, delete files, log keystrokes or provide an opening for further malware to get installed"	051 - Software Security, slide 12	051 - Software Security::s12::1	0.71	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 051 - Software Security, slide 12

A2b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain six techniques or behaviours by which malware such as viruses, worms and rootkits propagate themselves or conceal their activity on an infected system, as described in the lecture.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	A virus can spread by infecting the boot sector of a disk, as illustrated by Elk Cloner spreading through boot sector	"A program spread via boot sector infection"	051 - Software Security, slide 7	051 - Software Security::s07::1	0.36 LOW	partly supporte

	infection.					
2	A worm can propagate across a network by exploiting a remote execution feature of a service, as the Morris worm did with sendmail.	"Used a debugging feature of sendmail (remote execution)"	051 - Software Security, slide 7	051 - Software Security::s07::1	0.25 LOW	partly supporte
3	An executable COM virus appends its virus body to a program and redirects the program entry point to the virus code.	"Append a virus body to a program"	051 - Software Security, slide 9	051 - Software Security::s09::1	0.40 LOW	partly supporte
4	After running, the virus code restores the original entry point and jumps to it after its own execution"	"Virus code restores the original entry point and jumps to it after its own execution"	051 - Software Security, slide 9	051 - Software Security::s09::1	0.57	supported (ste gate)
5	An EXE virus overwrites the program header so that the entry point switches to the virus.	"Over write a program header to switch the entry point to a virus"	051 - Software Security, slide 10	051 - Software Security::s10::1	0.75	supported (ste gate)
6	A rootkit hides malicious processes and software so that the attacker keeps privileged remote access, and it is hard to detect because it hides from the very tools used to find it.	"Rootkits are a type of malware that mask malicious processes and software in the infected systems to ensure privileged remote access."	051 - Software Security, slide 13	051 - Software Security::s13::1	0.44 LOW	partly supporte

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 051 - Software Security, slide 10; 051 - Software Security, slide 13; 051 - Software Security, slide 7; 051 - Software Security, slide 9

PART A - QUESTION 3

A3a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain how a disclosure threat and a disruption threat each affect the confidentiality, integrity and availability of an information system, as described in the lecture.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	A disclosure threat involves unauthorized access to information (through snooping, sniffing or wiretapping) and is countered by confidentiality services, so it harms confidentiality.	"Disclosure - unauthorized access to information"	011 - Introduction to Computer Security, slide 10	011 - Introduction to Computer Security::s10::1	0.29 LOW	partly supporte
2	A disruption threat interrupts or prevents correct operation of the system and is countered by integrity services, so it harms availability of correct operation.	"Disruption - interruption or prevention of correct operation"	011 - Introduction to Computer Security, slide 10	011 - Introduction to Computer Security::s10::1	0.42 LOW	partly supporte

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.

© Hak Cipta Universiti Teknologi MARA

Citations: 011 - Introduction to Computer Security, slide 10

A3b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Discuss the Samy worm as a case study of a cross-site scripting attack, explaining how the malicious script was injected, how it spread between users, and what impact it had, as described in the lecture.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The attacker injected JavaScript into a user profile using document.body.innerHTML.	"Inject Javascript into a user profile using document.body.innerHTML"	052 - Web Security, slide 15	052 - Web Security::s15::1	0.78	supported (ste gate)
2	The worm obtained the list of the user's heroes by issuing a GET request on a user profile.	"Get the list of user's heros by using a GET on a user profile"	052 - Web Security, slide 15	052 - Web Security::s15::1	0.38 LOW	supported
3	The worm added Samy as a friend by performing XML-HTTP on the addFriends page.	"Add Samy as a field by performing XML-HTTP on the addFriends page"	052 - Web Security, slide 15	052 - Web Security::s15::1	0.78	supported (ste gate)
4	Any user visiting an infected user's page had their own profile and friends list infected with the JavaScript.	"Any user who visits an infected user's page will gets profile infected with Javascript and his friends list infected with Samy"	052 - Web Security, slide 15	052 - Web Security::s15::1	0.70	supported (ste gate)
5	The worm ultimately infected about 1,000,000 MySpace profiles.	"Eventually about 1,000,000 MySpace profiles were infected."	052 - Web Security, slide 15	052 - Web Security::s15::1	0.57	supported (ste gate)
6	The root cause is that any web application returning user input without filtering is a potential XSS vulnerability.	"Any web application that returns user input without filtering is a potential XSS vulnerability!"	052 - Web Security, slide 13	052 - Web Security::s13::1	0.77	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 052 - Web Security, slide 13; 052 - Web Security, slide 15

PART A - QUESTION 4

A4a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

State TWO (2) typical locations where network-based IDS sensors are placed in a network.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	A sensor can be positioned just inside the firewall.	"Just inside the firewall"	062 - Intrusion Detection System, slide 7	062 - Intrusion Detection System::s07::1	0.50	supported (ste gate)
2	A sensor can be positioned on the DMZ.	"On the DMZ"	062 - Intrusion Detection System, slide 7	062 - Intrusion Detection System::s07::1	0.25 LOW	supported

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 062 - Intrusion Detection System, slide 7

A4b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain three preventive network security mechanisms that an organization can deploy to protect its network, describing what each mechanism does to control or secure traffic.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	A firewall controls incoming and outgoing network traffic according to predetermined security policies.	"Control incoming and outgoing traffic on network with predetermined security policies."	061 - Network Security, slide 3	061 - Network Security::s03::1	0.80	supported (ste gate)
2	A proxy server acts as a firewall and web filter, provides shared network connections, and caches data to speed up common requests, improving data security and performance.	"Proxy servers act as a firewall and web filter, provide shared network connections, and cache data to speed up common requests."	061 - Network Security, slide 3	061 - Network Security::s03::1	0.83	supported (ste gate)
3	Network segmentation creates boundaries between network segments whose computing assets share a common function, risk or role.	"Boundaries between network segments where computing assets within the segment have a common function, risk or role within an organization."	061 - Network Security, slide 3	061 - Network Security::s03::1	0.77	supported (ste gate)
4	A remote access VPN gives individual hosts or clients remote and secure access to the organization's network.	"Provides remote and secure access to an organization network to individual hosts or clients"	061 - Network Security, slide 4	061 - Network Security::s04::1	0.89	supported (ste gate)
5	Zero Trust Network Access restricts each user to only the access and permission required to fulfill the role.	"A user should only has access and permission that required to fulfill the role"	061 - Network Security, slide 4	061 - Network Security::s04::1	0.64	supported (ste gate)
6	IDS/IPS detect or prevent network security attacks such as brute force attacks, Denial-of-Service attacks and exploits of network vulnerabilities.	"To detect or prevent the network security attacks such as brute force attacks, Denial-of-Service attacks and exploits of network vulnerabilities."	061 - Network Security, slide 4	061 - Network Security::s04::1	0.86	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 061 - Network Security, slide 3; 061 - Network Security, slide 4

PART A - QUESTION 5

A5a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

List two formal security models named in the lecture and, for each, state the specific security concern it is designed to address.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The Bell-La Padula (BLP) model is identified as a formal security model concerned with access control.	"Bell-La Padula (BLP) model: access control only"	024 - Formal Security Model, slide 5	024 - Formal Security Model::s05::1	0.67	supported (ste gate)
2	The Chinese Wall model is identified as addressing conflicts of	"Brewer and Nash's Chinese Wall Policy is designed to address a very specific concern: conflicts of	024 - Formal Security Model, slide 27	024 - Formal Security Model::s27::1	0.88	supported (ste gate)

© Hak Cipta Universiti Teknologi MARA

	interest for a consultant or contractor.	interest by a consultant or contractor."				

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 024 - Formal Security Model, slide 27; 024 - Formal Security Model, slide 5

A5b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Discuss the access control structures used to implement access policies, covering the access control matrix, access control lists and capabilities, and explain the requirements such structures must satisfy.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Name the access control matrix as one of the structures for implementing access policies.	"Access control structures are mechanisms for implementing access policies:"	023 - Access Control and Authorization, slide 7	023 - Access Control and Authorization::s07::1	0.83	supported (ste gate)
2	State that the access control matrix is a basic control structure whose advantages include clarity of definition and ease of verification.	"ACM is a basic control structure."	023 - Access Control and Authorization, slide 8	023 - Access Control and Authorization::s08::1	0.25 LOW	partly supporte
3	Identify the access control matrix's disadvantages as poor scalability and poor handling of changes.	"poor scalability"	023 - Access Control and Authorization, slide 8	023 - Access Control and Authorization::s08::1	0.25 LOW	partly supporte
4	Explain that an ACL describes access rights from the object's perspective, listing which subjects may access that object and how.	"ACL is an object-centered description of access rights:"	023 - Access Control and Authorization, slide 10	023 - Access Control and Authorization::s10::1	0.57	supported (ste gate)
5	Give one advantage of ACLs, such as easy access to an object's access rights or relative easiness of management using abstractions.	"easy access to object access rights"	023 - Access Control and Authorization, slide 10	023 - Access Control and Authorization::s10::1	0.40 LOW	supported
6	State the requirements that access control structures must meet, including expressing control policies, verifiability of correctness, and scalability and manageability.	"an ability to express control policies"	023 - Access Control and Authorization, slide 7	023 - Access Control and Authorization::s07::1	0.23 LOW	partly supporte

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 023 - Access Control and Authorization, slide 10; 023 - Access Control and Authorization, slide 7; 023 - Access Control and Authorization, slide 8

PART A - QUESTION 6

A6a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain how the chain of trust is established in the Trusted Computing architecture, referring to the role of

the TPM and the measurements taken during boot.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Each stage of the boot process measures and validates the next stage, with the resulting measurements recorded in the TPM's Platform Configuration Registers (PCRs).	"Each stage measures and validates the next one"	073 - Trusted Computing, slide 8	073 - Trusted Computing::s08::1	0.31 LOW	partly supporte
2	The chain begins at the hardware TPM and then extends through software components such as the RTM, TPM Software Stack, BIOS and kernel.	"The chain starts with the hardware TPM, then software:"	073 - Trusted Computing, slide 8	073 - Trusted Computing::s08::1	0.39 LOW	partly supporte

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 073 - Trusted Computing, slide 8

A6b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Describe the two primary system components of the Next Generation Secure Computing Base (NGSCB) and, for each component, state its role in the trusted platform.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Nexus is a special kernel that forms the core of the trusted operating environment.	"Special kernel (core of the trusted operating)"	073 - Trusted Computing, slide 13	073 - Trusted Computing::s13::1	0.62	supported (ste gate)
2	Nexus is a security kernel that is authenticated on boot.	"Security kernel, authenticated on boot"	073 - Trusted Computing, slide 14	073 - Trusted Computing::s14::1	0.80	supported (ste gate)
3	Nexus authenticates trusted programs.	"Authenticates trusted programs"	073 - Trusted Computing, slide 14	073 - Trusted Computing::s14::1	0.75	supported (ste gate)
4	Nexus provides the application interface to the TPM.	"Application interface to TPM"	073 - Trusted Computing, slide 14	073 - Trusted Computing::s14::1	0.60	supported (ste gate)
5	The Nexus Computing Agent (NCA) is a trusted software component.	"Trusted software component"	073 - Trusted Computing, slide 15	073 - Trusted Computing::s15::1	0.33 LOW	supported
6	The NCA runs in a trusted mode that communicates with Nexus.	"Runs in trusted mode that communicates with Nexus"	073 - Trusted Computing, slide 15	073 - Trusted Computing::s15::1	0.83	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 073 - Trusted Computing, slide 13; 073 - Trusted Computing, slide 14; 073 - Trusted Computing, slide 15

PART A - QUESTION 7

A7a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

A biometric system performs identification and authentication through a sequence of stages. List TWO (2) stages that belong to the authentication stage of this process.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Comparison of the	"Authentication Stage	072 - Biometrics	072 - Biometrics	0.14 LOW	partly supporte

	acquired biometric sample against the stored master characteristics	Acquisition(s) Comparison Decision"	and Authentication, slide 5	and Authentication::s05::1		
2	A decision reached on the outcome of the comparison	"Comparison Decision"	072 - Biometrics and Authentication, slide 5	072 - Biometrics and Authentication::s05::1	0.50	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 072 - Biometrics and Authentication, slide 5

A7b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

State the definition of a biometric as given in the course, and state the two sectors into which today's biometric applications are categorised. Then state one example technology from each sector.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	A biometric is defined as a physiological or behavioural characteristic of a human being that can distinguish one person from another.	"A biometric is a physiological or behavioural characteristic of a human being that can distinguish one person from another"	072 - Biometrics and Authentication, slide 2	072 - Biometrics and Authentication::s02::1	0.89	supported (ste gate)
2	Such a characteristic can theoretically be used for identification or verification of identity.	"that theoretically can be used for identification or verification of identity"	072 - Biometrics and Authentication, slide 2	072 - Biometrics and Authentication::s02::1	0.83	supported (ste gate)
3	Biometric applications available today are categorised into two sectors.	"Biometric applications available today are categorized into 2 sectors"	072 - Biometrics and Authentication, slide 4	072 - Biometrics and Authentication::s04::1	0.86	supported (ste gate)
4	The two sectors are the physiological (listed as 'psychological' in the slide) sector and the behavioural sector.	"Psychological: Iris, Fingerprints, Hand, Retinal and Face recognition"	072 - Biometrics and Authentication, slide 4	072 - Biometrics and Authentication::s04::1	0.25 LOW	partly supporte
5	The second sector is the behavioural sector.	"Behavioural: Voice, Typing pattern, Signature"	072 - Biometrics and Authentication, slide 4	072 - Biometrics and Authentication::s04::1	0.33 LOW	supported
6	An example physiological technology is the fingerprint, which divides the print into loops, whorls and arch and calculates minutiae points.	"Divides print into loops, whorls and arch"	072 - Biometrics and Authentication, slide 6	072 - Biometrics and Authentication::s06::1	0.46 LOW	partly supporte

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 072 - Biometrics and Authentication, slide 2; 072 - Biometrics and Authentication, slide 4; 072 - Biometrics and Authentication, slide 6

PART A - QUESTION 8

A8a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain the difference between morals, ethics and laws as three forms of guidance for professional conduct in computer security.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Morals are described as traditions of belief about right and wrong conduct, forming the bedrock of social behaviour.	"Morals are traditions of belief about right and wrong conduct and "doing what is morally right" is the bedrock of our social behavior"	071 - Ethics and Computer Security, slide 5	071 - Ethics and Computer Security::s05::1	0.82	supported (ste gate)
2	Laws are formal rules of conduct imposed by a sovereign authority such as a government on its subjects or citizens.	"Laws are formal rules of conduct that a sovereign authority, such as a government, imposes on its subjects or citizens"	071 - Ethics and Computer Security, slide 5	071 - Ethics and Computer Security::s05::1	1.00	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 071 - Ethics and Computer Security, slide 5

A8b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Refer to your answer in (a). Explain six requirements that a professional code of ethics and conduct, such as the ACM code, places on a computing professional working in computer security.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The professional must contribute to society and human well-being, recognising that all people are stakeholders in computing.	"Contribute to society and to human well-being, acknowledging that all people are stakeholders in computing."	071 - Ethics and Computer Security, slide 11	071 - Ethics and Computer Security::s11::1	0.73	supported (ste gate)
2	The professional must avoid causing harm through their work.	"Avoid harm."	071 - Ethics and Computer Security, slide 11	071 - Ethics and Computer Security::s11::1	0.29 LOW	supported
3	The professional must respect the privacy of others.	"Respect privacy."	071 - Ethics and Computer Security, slide 11	071 - Ethics and Computer Security::s11::1	0.40 LOW	supported
4	The professional must honour confidentiality of information entrusted to them.	"Honor confidentiality."	071 - Ethics and Computer Security, slide 11	071 - Ethics and Computer Security::s11::1	0.14 LOW	supported
5	The professional is expected to keep up high standards of competence, conduct and ethical practice in their work.	"Maintain high standards of professional competence, conduct, and ethical practice."	071 - Ethics and Computer Security, slide 12	071 - Ethics and Computer Security::s12::1	0.70	supported (ste gate)
6	The professional should only access computing and communication resources when authorised or when the public good compels it.	"Access computing and communication resources only when authorized or when compelled by the public good."	071 - Ethics and Computer Security, slide 12	071 - Ethics and Computer Security::s12::1	0.75	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 071 - Ethics and Computer Security, slide 11; 071 - Ethics and Computer Security, slide 12

PART A - QUESTION 9

A9a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain two password security controls that can be applied to password files and user accounts to reduce the risk of password compromise.

Marking points:

© Hak Cipta Universiti Teknologi MARA

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Access control should be applied to the password files so that they are protected from unauthorised reading.	"Access control applied to password files"	022 - Identification and Authentication, slide 12	022 - Identification and Authentication::s12::1	0.40 LOW	partly supporte
2	Accounts should be de-activated after multiple failed login attempts to block repeated guessing.	"De-activation of accounts after multiple failed logins"	022 - Identification and Authentication, slide 12	022 - Identification and Authentication::s12::1	0.55	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 022 - Identification and Authentication, slide 12

A9b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

State three motivations for adopting single sign-on, and state three design criteria that Kerberos satisfies as an SSO solution.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	One motivation for SSO is to reduce the need for users to memorize passwords.	"Reduce the need to memorize passwords"	022 - Identification and Authentication, slide 16	022 - Identification and Authentication::s16::1	0.57	supported (ste gate)
2	One motivation for SSO is to reduce the time users spend typing passwords.	"Reduce the time spent on typing passwords"	022 - Identification and Authentication, slide 16	022 - Identification and Authentication::s16::1	0.43 LOW	supported
3	One motivation for SSO is to reduce the effort of password maintenance.	"Reducing password maintenance effort"	022 - Identification and Authentication, slide 16	022 - Identification and Authentication::s16::1	0.67	supported (ste gate)
4	Kerberos provides security against eavesdropping by never transmitting passwords in clear text.	"Security against eavesdropping: no password transmission in clear text."	022 - Identification and Authentication, slide 18	022 - Identification and Authentication::s18::1	0.60	supported (ste gate)
5	Kerberos provides reliability because every use of a service requires prior authentication.	"Reliability: every use of a service requires prior authentication."	022 - Identification and Authentication, slide 18	022 - Identification and Authentication::s18::1	0.67	supported (ste gate)
6	Kerberos provides transparency because the user is unaware of any authentication beyond the initial login.	"Transparency: user is not aware of any authentication beyond an initial login."	022 - Identification and Authentication, slide 18	022 - Identification and Authentication::s18::1	0.64	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 022 - Identification and Authentication, slide 16; 022 - Identification and Authentication, slide 18

PART A - QUESTION 10

A10a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

State TWO (2) ways in which an intrusion detection system supports the detection and defence of a system against attacks, as described in the lecture.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment

© Hak Cipta Universiti Teknologi MARA

1	An IDS can confirm whether an attack succeeded or failed by examining host-based IDS log entries.	"Verifies success or failure of attack by reviewing HIDS log entries"	062 - Intrusion Detection System, slide 14	062 - Intrusion Detection System::s14::1	0.25 LOW	supported
2	An IDS provides detection and response to attacks in near real time.	"Near real-time detection and response"	062 - Intrusion Detection System, slide 14	062 - Intrusion Detection System::s14::1	0.62	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 062 - Intrusion Detection System, slide 14

A10b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Compare the three security concepts of vulnerability, threat and attack as defined in the lecture, and explain how protection mechanisms are organised to counter threats to assets.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	A vulnerability is described as a weakness of a system that can be exploited to damage assets.	"Vulnerabilities: Weakness of a system that can be exploited to damage assets"	011 - Introduction to Computer Security, slide 9	011 - Introduction to Computer Security::s09::1	1.00	supported (ste gate)
2	A threat is characterised as a potential violation of security rather than an actual one.	"Threats: A threat is a "potential" violation of security"	011 - Introduction to Computer Security, slide 9	011 - Introduction to Computer Security::s09::1	0.50	supported (ste gate)
3	An attack is characterised as the actual violation of security.	"Attacks: The actual violation of security"	011 - Introduction to Computer Security, slide 9	011 - Introduction to Computer Security::s09::1	0.80	supported (ste gate)
4	A threat is also defined as an object, person or other entity representing a constant danger to an asset.	"Threat: object, person, or other entity representing a constant danger to an asset"	011 - Introduction to Computer Security, slide 28	011 - Introduction to Computer Security::s28::1	0.82	supported (ste gate)
5	An attack is defined as a deliberate act that exploits a vulnerability.	"Attack: a deliberate act that exploits vulnerability"	011 - Introduction to Computer Security, slide 28	011 - Introduction to Computer Security::s28::1	0.83	supported (ste gate)
6	Protection of assets is organised around prevention, detection and response techniques.	"Protection of assets encompasses prevention, detection and response techniques"	011 - Introduction to Computer Security, slide 28	011 - Introduction to Computer Security::s28::1	0.75	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 011 - Introduction to Computer Security, slide 28; 011 - Introduction to Computer Security, slide 9

PART B - QUESTION 1

B1a - 5 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain the goals that access control pursues and the role of the reference monitor in authorization, then describe how reference monitors relate to access control policies and where they may be deployed in a system.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	State that access	"Goals of access control: Granting	023 - Access	023 - Access	0.88	supported (ste

© Hak Cipta Universiti Teknologi MARA

	control has four goals: granting, limiting, preventing and revoking access.	access Limiting access Preventing access Revoking access"	Control and Authorization, slide 4	Control and Authorization::s04::1		gate)
2	Identify the reference monitor as the component that makes authorization decisions.	"Reference monitor makes authorization decisions."	023 - Access Control and Authorization, slide 4	023 - Access Control and Authorization::s04::1	1.00	supported (ste gate)
3	Explain that reference monitors are the instruments used to realize access control policies.	"Reference monitors are instruments for realization of access control policies."	023 - Access Control and Authorization, slide 18	023 - Access Control and Authorization::s18::1	1.00	supported (ste gate)
4	Note that reference monitors can be deployed at every level of the system hierarchy.	"They can be deployed at all levels of system hierarchy."	023 - Access Control and Authorization, slide 18	023 - Access Control and Authorization::s18::1	0.56	supported (ste gate)
5	Explain that access control methods implement policies governing which subjects may access which objects and in what manner.	"Access control methods implement policies that control which subjects can access which objects in which way."	023 - Access Control and Authorization, slide 18	023 - Access Control and Authorization::s18::1	0.70	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 023 - Access Control and Authorization, slide 18; 023 - Access Control and Authorization, slide 4

B1b - 5 marks - supported by lecture slides (not lecturer-marked)

Question:

*State the Chinese Wall model's simple security rule and its *-property, explain the type of policy the model represents, and describe how its permissions behave over time.*

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The simple security rule permits a subject to access an object only when the object is either within the Wall (in the same company datasets as objects the subject has already accessed) or in a completely different conflict of interest class.	"is in the same company datasets as the objects already accessed by s, that is, "within the Wall," or belongs to an entirely different conflict of interest class."	024 - Formal Security Model, slide 25	024 - Formal Security Model::s25::1	0.52	supported (ste gate)
2	The Chinese Wall *-property allows a write only if the simple security rule permits the access and the subject cannot read any unsanitized object belonging to a different company dataset than the one being written to.	"Write access is only permitted if: access is permitted by the simple security rule, and no object can be read which is: in a different company dataset than the one for which write access is requested, and contains unsanitized information."	024 - Formal Security Model, slide 26	024 - Formal Security Model::s26::1	0.59	supported (ste gate)
3	The Chinese Wall policy is strictly speaking not an integrity policy but an access control confidentiality policy.	"Strictly speaking, this is not an integrity policy, but an access control confidentiality policy."	024 - Formal Security Model, slide 21	024 - Formal Security Model::s21::1	0.82	supported (ste gate)
4	A subject may access information from any company provided it has never accessed information from a different company in the same conflict class.	"A subject may access information from any company as long as that subject has never accessed information from a different company in the same conflict class."	024 - Formal Security Model, slide 24	024 - Formal Security Model::s24::1	0.92	supported (ste gate)

© Hak Cipta Universiti Teknologi MARA

5	Permissions in the Chinese Wall model change dynamically, since the access rights a subject enjoys depend on the history of its past accesses.	"Notice that permissions change dynamically. The access rights that any subject enjoys depends on the history of past accesses"	024 - Formal Security Model, slide 24	024 - Formal Security Model::s24::1	0.71	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 024 - Formal Security Model, slide 21; 024 - Formal Security Model, slide 24; 024 - Formal Security Model, slide 25; 024 - Formal Security Model, slide 26

PART B - QUESTION 2

B2a - 5 marks - supported by lecture slides (not lecturer-marked)

Scenario:

A computing professional joins a group that has a documented set of acceptable behaviors, and the group defines which specific actions are appropriate or inappropriate. The group also publishes a code of ethics and professional conduct, but some members argue that such a code may not reflect the ethics of every member and is often not enforceable.

Question:

Explain five points about how a professional code of ethics, such as the ACM code, guides the ethical conduct of a computing professional, including what such a code is and the limitations of relying on it.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	A code of ethics is a documented set of acceptable behaviors for a professional or social group.	"Documented set of acceptable behaviors for professional or social groups."	071 - Ethics and Computer Security, slide 6	071 - Ethics and Computer Security::s06::1	0.78	supported (ste gate)
2	The code is defined by the group itself rather than imposed from outside.	"Defined by the group."	071 - Ethics and Computer Security, slide 6	071 - Ethics and Computer Security::s06::1	0.25 LOW	partly supporte
3	The code identifies specific actions as either appropriate or inappropriate.	"Identifies specific actions as appropriate or inappropriate."	071 - Ethics and Computer Security, slide 6	071 - Ethics and Computer Security::s06::1	0.60	supported (ste gate)
4	A limitation is that the code may not reflect the ethics of every member of the group.	"May not reflect the ethical of every member of the group."	071 - Ethics and Computer Security, slide 9	071 - Ethics and Computer Security::s09::1	0.78	supported (ste gate)
5	Another limitation is that the code is often not enforceable because it is a code of conduct, not a legal document.	"Many times it isn't enforceable. It's a code of conduct, not a legal document."	071 - Ethics and Computer Security, slide 9	071 - Ethics and Computer Security::s09::1	0.60	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 071 - Ethics and Computer Security, slide 6; 071 - Ethics and Computer Security, slide 9

B2b - 5 marks - supported by lecture slides (not lecturer-marked)

Question:

Discuss five points on how privacy and organizational responsibility apply to the scenario, where the group publishes a code of ethics and professional conduct. Your answer should consider the ethical dimensions of handling personal information and the responsibilities the group and its members bear.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Privacy is an ethical concern in security that	"Protecting one's personal information"	071 - Ethics and Computer	071 - Ethics and Computer Security::s13::1	0.33 LOW	partly supporte

© Hak Cipta Universiti Teknologi MARA

	involves protecting an individual's personal information.		Security, slide 13			
2	Organizations must ensure information accuracy, which concerns the authentication and fidelity of information held about people.	"Deals with authentication and fidelity of information"	071 - Ethics and Computer Security, slide 13	071 - Ethics and Computer Security::s13::1	0.27 LOW	partly supporte
3	Responsibility extends to information property, namely who owns information about individuals and how it may be sold or exchanged.	"Deals with who owns information about individuals and how information can be sold and exchanged"	071 - Ethics and Computer Security, slide 13	071 - Ethics and Computer Security::s13::1	0.64	supported (ste gate)
4	Organizations must address information accessibility, that is, what information a person has the right to obtain about others and how it can be used.	"Deals with what information a person has the right to obtain about others and how the information can be used"	071 - Ethics and Computer Security, slide 13	071 - Ethics and Computer Security::s13::1	0.67	supported (ste gate)
5	The group's published code of ethics and professional conduct, such as that of the ACM, is a formal organizational instrument for guiding members' responsible handling of privacy.	"has a code of ethics and professional conduct"	071 - Ethics and Computer Security, slide 7	071 - Ethics and Computer Security::s07::1	0.25 LOW	partly supporte

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 071 - Ethics and Computer Security, slide 13; 071 - Ethics and Computer Security, slide 7

End of marking scheme.

© Hak Cipta Universiti Teknologi MARA